

面向 LLM 安全情报采集的混合控制智能体： 可审计预算约束下的自主检索与无强化学习 决策增强

作者待补

单位待补

邮箱待补

摘要—大语言模型（LLM）应用安全威胁证据分散于 NVD、CISA KEV、OSV 与 arXiv 等异构公开源。开放式采集若仅依赖固定源轮询与模板检索，难以在有限 API 预算下兼顾覆盖完整性与噪声控制。本文报告一套面向 LLM 安全领域的情报采集智能体系统：在 Claude Agent SDK 原生工具循环中赋予智能体检索词生成与高级算子组合能力，同时由确定性 Python 控制面保留轮次骨架、预算安全阀、UCB 组合审批与持久化，形成混合控制面。在不引入 Agentic 强化学习的前提下，系统以 UCB 风格效用对智能体提交的查询候选做审批门控，并以自然语言技巧库（Playbook）跨运行沉淀高收益算子组合。离线回放 33 次历史运行、617 轮查询结果表明，相对全源轮询基线，自适应 UCB 的归一化 regret 由 1.245 降至 1.063；端点能力矩阵上工具调用与结构化决策解析成功率均达 100%。本文贡献在于给出可审计、可降级的自主采集架构，并明确无 RL 条件下检索决策增强的工程边界。

Index Terms—大语言模型安全，网络威胁情报，自主智能体，混合控制，多臂老虎机，工具调用，可审计性

ABSTRACT (ENGLISH)

Evidence of LLM-application security threats is scattered across heterogeneous public feeds such as NVD, CISA KEV, OSV, and arXiv. Open-ended collection with fixed source rotation and template queries struggles to balance coverage and noise under a finite API budget. We present an intelligence-collection agent for the LLM-security domain that grants free-form query generation and advanced operator composition inside a Claude Agent SDK tool loop, while a deterministic Python control plane retains the round skeleton, budget safety valves, UCB portfolio approval,

and persistence—a *hybrid control plane*. Without Agentic reinforcement learning, the system gates agent-proposed query candidates with a UCB-style utility and accumulates high-yield operator recipes in a natural-language Playbook across runs. Offline replay over 33 historical runs and 617 rounds shows that adaptive UCB reduces normalized regret from 1.245 to 1.063 versus round-robin; an endpoint capability matrix reports 100% success for both tool calling and structured decision parsing. We contribute an auditable, degradable autonomous collection architecture and clarify the engineering boundary of retrieval-decision improvement without RL.

I. 引言

LLM 正以对话助手、检索增强生成（RAG）应用与工具调用智能体等形式进入生产系统。随之而来的是一类相对独立的安全问题：提示注入、越狱、RAG 投毒、智能体工具滥用、模型供应链风险等，已被 OWASP LLM Top 10 系统化 [?], 并在真实集成场景中得到实证 [?]. 与单一 CVE 订阅不同，这类威胁的证据高度碎片化：可利用漏洞常先出现在 NVD [?] 与 CISA KEV [?]; 受影响开源组件出现在 OSV [?]; 攻击手法与防御评估则往往更早出现在 arXiv 预印本 [?]. 因此，面向 LLM 安全的情报采集天然是多源、多模态、预算受限的序贯决策问题。

现有流水线常见做法是：固定源集合轮询、按话题关键词表生成模板查询、由用户指定最大轮数。黑

板 (blackboard) 上虽已记录 novelty、duplicate ratio、noise ratio 与覆盖缺口, 这些信号却很少真正进入决策者。与此同时, 完全放开智能体自主调用外部 API 又会带来预算失控、重复查询与不可审计风险。Agentic AI 在网络安全中的机遇与治理缺口已被广泛讨论 [?], [?], 但针对 **LLM 安全情报采集** 这一具体任务, 仍缺少可落地的、把自主性关进可审计控制面的系统报告。

本文聚焦两个相互耦合的研究问题:

- **RQ1 (混合控制)**: 如何在赋予智能体轮内检索自主性的同时, 用确定性控制面保证预算、去重与终止条件可审计、可强制执行?
- **RQ2 (无 RL 决策增强)**: 在不训练策略网络的前提下, 如何用 UCB 审批门控与跨运行 Playbook, 提升源/查询/算子选择的长期收益?

我们的回答是一套已落地的自包含引擎 (backend/intel_agent): 智能体在 MCP 白名单工具上自由组合高级检索算子 [?], [?]; 控制面以 hooks、UCB 组合选择与多层 fallback 约束其行为 [?]; Playbook 以自然语言技巧形式沉淀可复用经验。下游知识图谱构建 (如 CTINexus [?]) 与采集解耦, 失败互不阻断。

贡献概括:

- 1) 提出并实现面向 LLM 安全情报采集的**混合控制面架构**: SDK 工具循环负责探索, Python 控制器负责预算、审批、覆盖与落盘。
- 2) 给出**无 RL** 的检索决策增强路径: 智能体提案 $\rightarrow$ UCB 效用审批 $\rightarrow$ 归一化奖励回写 $\rightarrow$ Playbook 召回/衰减。
- 3) 报告可复核的子系统证据: UCB 离线 regret 对比、端点能力矩阵, 以及与确定性规则基线共享的降级契约。

II. 相关工作

A. LLM 安全与威胁情报

提示注入与间接注入揭示了“数据即指令”的新攻击面 [?]; OWASP 持续维护 LLM 应用风险清单 [?]. 传统 CTI 强调 STIX/TAXII 结构化交换与 ATT&CK 知识组织, 而 LLM 安全证据大量仍以漏洞公告与学术摘要形式存在。CTINexus 展示了用 LLM 上下文学习从非结构化 CTI 构建知识图谱的路径 [?], 但其输入假设情报文本已可得。本文关注其上游: 如何在预算约束下从活源采到可用情报。

B. 工具调用智能体

ReAct 将推理轨迹与环境动作交错, 使 LLM 能基于观察修正计划 [?]; Toolformer 表明模型可自学何时调用工具 [?]. Claude Agent SDK 进一步提供进程内自定义工具、hooks 与会话管理 [?], [?]. 本文不把智能体当作端到端黑盒执行器, 而是将其嵌入混合控制面: 轮内动作可自主, 轮间状态与安全阀由确定性代码掌握。

C. 检索中的多臂老虎机

信息检索中, 多查询可被同时保持为活跃臂, 由 bandit 在速率限制下分配拉取轮次 [?]; 文档判定与主题查询识别也可建模为探索-利用问题 [?], [?]. UCB1 提供有限时间 regret 保证且实现简单 [?]. 与直接让 bandit 执行查询不同, 本文将 UCB 用作**审批门**: 臂由智能体提出 (含高级算子签名), 确定性评分决定本轮至多批准的调用组合, 从而保留语义生成能力又限制工具滥用。

D. Agentic 网络安全

近期综述与政策讨论强调自主智能体在 SOC 自动化中的潜力及其治理缺口 [?], [?]. 本文贡献是领域收窄后的可运行架构: 固定威胁话题分类 (Core/Extended)、四源 typed 工具、可观测黑板与离线可回放的决策日志。

III. 问题设定与设计目标

设采集运行由轮次 $t = 1, \dots, T$ 组成, 每轮可发起有限次源 API 调用。状态包含: 已采集去重条目集合、各 Core 话题覆盖缺口、历史查询收益、剩余 API 预算。动作空间为四元组 ($source, query, operators, stop$)。设计目标:

- 1) **自主性**: 查询文本与算子组合由智能体在工具循环中生成, 而非仅模板改写。
- 2) **可审计预算**: 任何调用可追溯至批准的候选 ID; 超预算、未批准调用被 hooks/处理器拒绝。
- 3) **可降级**: SDK 不可用或结构化决策失败时, 行为不低于共享规则基线。
- 4) **可演化**: 高收益算子组合跨运行沉淀, 低收益技巧衰减。

非目标: 本文不训练 Agentic RL 策略; 不把 item 级知识图谱融合纳入采集主循环。

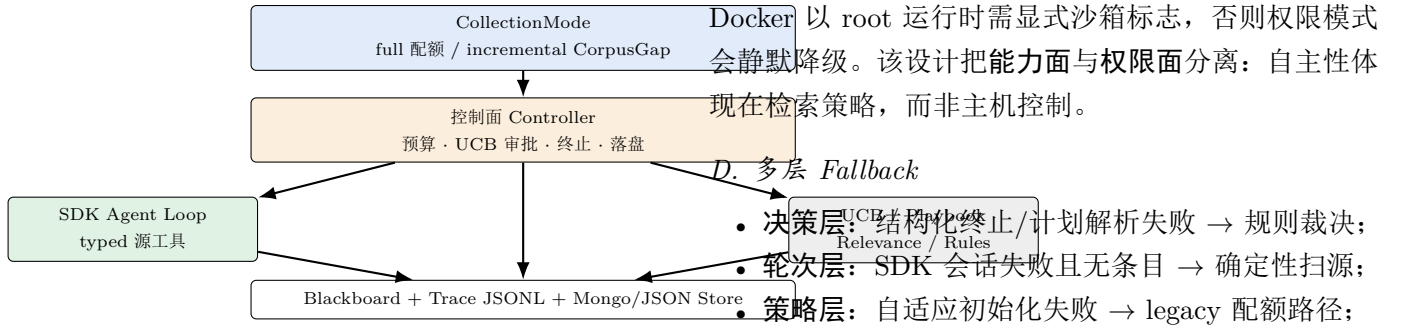


图 1. 混合控制面架构：智能体负责轮内检索探索，控制面与确定性模块负责审批、度量与持久化。

Algorithm 1 混合控制面单轮协议

- 1: 召回 Playbook 技巧；渲染黑板摘要 digest（禁止倾倒全文）
- 2: 启动/恢复 SDK 会话；智能体调用源工具并提交本轮摘要
- 3: 若无有效采集 则运行规则 fallback 轮次
- 4: 三层相关性标注；合并入 blackboard；harvest 高收益技巧
- 5: 重算 CorpusGap / RunGap；记录每调用归一化奖励
- 6: Critic + 饱和/停滞/预算规则决定是否继续

IV. 系统架构：混合控制面

A. 总体结构

系统分为四层（图 1）：（1）**模式层**定义全量（full）与增量（incremental）目标；（2）**控制面**（IntelAgentController）编排轮次、相关性标注、缺口重算、终止与持久化；（3）**智能体面**（IntelAgentLoop）在 SDK 会话中调用 MCP 工具；（4）**确定性增强**含 UCB、Playbook、三层相关性与规则 fallback。

B. 单轮协议

每轮执行算法 1。关键不变量是：**智能体可以提案，但不能绕过审批与预算**。自适应增量模式下，源工具调用必须携带已批准的 `candidate_id`；PreToolUse hook 在预算耗尽或未批准时拒绝调用 [?]

C. 安全边界与工具白名单

进程内 MCP 仅暴露源搜索、状态查询、候选评分、Playbook 与轮次摘要工具；禁用 Bash/文件系统类内建工具，避免“采集智能体”演变为通用代码代理。

V. 无 RL 的检索决策增强

A. 智能体提案与 UCB 审批

自适应增量中，智能体通过 `score_query_candidates` 提交 1-8 个候选。臂键为

`topic | channel | source | intent | operator_signature`.

效用近似为

$$u = \hat{r} - 0.2 \text{ noise} - 0.2 \text{ dup} + \sqrt{\frac{2 \ln(n+2)}{n_a + 1}},$$

其中 $\hat{r}$ 融合目标缺口优先级与历史均值奖励，末项为 UCB 探索奖励 [?]。select_portfolio 每轮最多批准 4 次调用，并对 discovery/confirmation 意图施加预算占比上限。该机制把 bandit 从“替智能体选动作”改为“对智能体提案做资源分配”，更贴近 IR 中在速率限制下调度多个查询的设定 [?], [?]

B. 归一化奖励

单次调用奖励由缺口优先级下降、discovery/confirmation 加成，以及噪声/重复惩罚组成，裁剪到 $[-1, 1]$ 。奖励进入 `query_outcomes`，既服务在线 UCB，也支持离线回放对比。

C. Playbook 自演化

高产调用（例如每调用新增相关条目 ≥ 0.5 ）被 harvest 为自然语言技巧，键为 `topic_bucket :: source :: operator_signature`。下轮按语义相似与历史收益召回 Top-k 注入 digest；长期低收益条目衰减并可能废弃。与参数化策略梯度不同，Playbook 是可人工审阅的经验记忆，适合安全运营场景对可解释性的要求。

D. 高级检索算子

typed 工具直接暴露各源算子：NVD 的 CWE/CVSS/时间窗/KEV；arXiv 的布尔与分类限定；OSV 的生态/包/purl；CISA KEV 的 CVE 列表。算子签名进入臂键，使“会用高级语法”的查询与裸关键词查询在统计上可区分。

E. 为何暂不做 *Agentic RL*

当前主流托管模型不可本地训练；相关性金标尚未规模化，奖励噪声会主导策略更新；而上下文工程、UCB 门控与 Playbook 的边际收益仍未耗尽。本文将 RL 留作评估基线成熟后的重估选项。

VI. 相关性、覆盖与终止

三层过滤（规则 → embedding → flash LLM）把条目标为相关/不相关/不确定，并写入 `method` 字段以便分层评估。Full 模式以 Core 话题配额驱动覆盖；Incremental adaptive 以历史语料上的 CorpusGap（话题 × 证据渠道）驱动软覆盖。终止由 critic 解释，但硬约束顺序为：`max_rounds` / API 预算 / 超时 → 饱和或停滞 → `min_rounds` 下限。自适应路径在连续低收益且最大 UCB 效用过低时标记缺口耗尽并停止，避免在不可达主题上空转。

VII. 实现与运行形态

系统以 Python 包自包含交付，CLI 提供 `full/incremental/latest`。可选 MongoDB 以 `item_id` 全局去重并服务 CorpusGap；`--verbose` 将工具调用与 critic 决策落入 JSONL，供控制台实时订阅。采集与 `ctinexus_kg` 禁止互相 import，仅通过 `run_id` 与持久化条目交接。

VIII. 评估证据

A. 端点能力矩阵

在 DeepSeek Anthropic 兼容端点上，工具调用成功率 20/20，tool-forcing 结构化决策解析 20/20（目标分别为 $\geq 95\%$ 与 $\geq 90\%$ ）。子智能体与提示缓存未达标，故终止 critic 采用独立快速结构化调用，上下文靠摘要压缩而非缓存。

B. UCB 离线回放

对历史 blackboard 中的 `query_outcomes` 回放（33 次运行、617 轮），自适应 UCB 归一化 regret 为 **1.063**，全源轮询为 **1.245**，满足“不低于轮询”的验收门槛。该实验不消耗在线 API，可重复。

C. 在线冒烟

一次全量冒烟在 API 预算用尽前采集 255 条，多数 Core 话题达到配额，残留缺口可观测。这证明控制面预算阀与覆盖记账可用，但不能替代同预算 A/B 与人工精确率抽检。

D. 局限

完整同预算 A/B（冻结目标 × 引擎 × 重复）与人工金标精确率仍在进行中；因此本文不宣称端到端“智能提升百分比”，而将 UCB regret 与端点可靠性作为子系统级证据。相关性规则层仍可能偏乐观，需依赖第 2-3 层与人工校准。

IX. 讨论

RQ1. 混合控制面把“自主”限定在检索策略空间：智能体可生成查询与算子，但不能突破预算、白名单与审批。hooks + 候选 ID + 共享规则 fallback 使每次降级可审计，这与纯 ReAct 式端到端代理形成对照 [?]。

RQ2. UCB 审批保留探索项，同时用缺口优先级引导利用；Playbook 提供跨运行记忆而无须可微策略。该组合回答了“无 RL 还能提升什么”：提升的是资源分配与经验复用，不是端到端策略最优性。

对运营的启示是：开放采集应先定义覆盖与预算目标，再谈智能体；否则无法区分“更聪明”与“更会烧配额”。

X. 结论与展望

本文报告了面向 LLM 安全情报采集的混合控制智能体：以 SDK 工具循环实现轮内自主检索，以确定性控制面保证可审计预算与可降级行为，并以 UCB 审批与 Playbook 在无 RL 条件下增强决策。后续工作包括完成同预算 A/B 与人工精确率协议、强化增量水位线在 Mongo 模式下的端到端验证，以及将高置信条目接入知识图谱融合流水线。

致谢

作者信息与资助声明待补。

数据与代码可用性

系统实现位于项目仓库 `backend/intel_agent/`;
UCB 回放脚本为 `scripts/bandit_replay.py`; 运行
轨迹可导出为 JSONL。活源 API 密钥与原始情报文本
因许可与敏感原因不公开完整转储。

作者贡献 (CRediT)

待作者名单确定后按 CRediT 十四项角色填写。

利益冲突

作者声明无利益冲突。

AI 使用披露

本文初稿由学术写作辅助智能体基于系统代码与
内部技术文档生成，经作者审阅、核实引用与实验数字
后定稿。所有参考文献均要求可通过 DOI 或官方文档
核验；未核验条目不得保留。